



AGENT AUTHORIZATION

Agent Auth Gate

Scoped, delegatable, revocable API access for AI agents. Point it at an OpenAPI spec and its upstream — agents prove an identity, receive a capability token, and can only ever do less.

● Alpha • building with you Built on macaroons

Agents need access that narrows

What agents are handed today

- **API keys**

Long-lived and all-or-nothing. One secret, full access, no expiry.

- **Bearer JWTs**

Identify the caller but never narrow — handing work to a sub-agent means a round-trip to the issuer.

What they actually need

Scoped to the exact operations it may call.

Delegatable to a sub-agent with strictly less authority.

Revocable cutting the whole lineage at once.

THE IDEA

Capability tokens, built on macaroons

A macaroon's authority is an HMAC-chained list of caveats. The chain enforces three properties — no policy server in the request path.

01

States its authority

The token names exactly which operations it may call. Anything outside that set is denied by default.

02

Narrows offline

Any holder appends a caveat to derive a smaller token. No signing key. No call to the issuer.

03

Can't widen

Remove a caveat and the HMAC chain breaks. Authority only ever shrinks — never grows.

token

+ caveat →

narrower

+ caveat →

narrower still

— each link re-keys the chain

How the gate works

register → `• identity • Ed25519`

↳ `capability token` scoped to operations

`GET /orders` → proxy → `allow • 200`

`POST /orders` → proxy → `deny • 403`

a denied request never reaches the upstream API

IDENTITY	Signed JWT exchanged for a scoped token.
ENFORCE	Proxy matches (method, path) to caveats. Deny by default.
DELEGATE	Narrow offline, hand the smaller token to a sub-agent.
REVOKE	Kill the root id; the entire lineage fails next call.
APPROVE	An operation can require a human to sign off first.

Scoped access

PROMPT

"List the current orders."

GET

/orders

200

PROMPT

"Create an order for 5 blue widgets."

POST

/orders

201

SWIRLS_ Reads and writes pass — the machine's token is scoped to both.

Least-privilege delegation

PROMPT

"Delegate a **read-only** sub-agent. Read the orders with its token, then have it try to create one. Show me what happened and why."

root — narrow offline → sub-agent · read-only

GET /orders 200

POST /orders 403

SWIRLS_ The child is boxed in below the parent — and no server was contacted to make its token.

Held for approval

PROMPT

"Delegate a sub-agent that can read freely but whose order creation requires my approval. Have it try to create an order."

POST /orders 403 • approval_required

• pending in the Approvals tab → operator clicks Approve

POST /orders retry 201

SWIRLS_ Click Deny instead and the retry stays blocked.

Revocation

Sessions → Revoke one click, in the portal

PROMPT

"Read the orders again and tell me what happened."

root /orders

sub-agent /orders

sub-sub /orders

403 • grant_revoked

403 • grant_revoked

403 • grant_revoked

SWIRLS_ Revoke the root id and the entire lineage dies on the next call.

NOT A RESEARCH DESIGN

Already how production tokens work

Proven construction

Fly.io runs macaroons for service tokens across their network. Swirls uses them for service-to-service auth and for Swirls Service Tokens.

KMS / HSM ready

Dependency-free TypeScript. The root key sits behind one cached operation — no per-request round-trip to the signer.

Spec-driven

Capabilities, the authorization vocabulary, and guarded paths all derive from the OpenAPI doc. Verified on a Pet Store spec, zero changes.

⚡ Deny by default. Narrow offline. Revoke the lineage.

APPENDIX

Run it yourself

SET UP — THREE TERMINALS

```
1 • bun run demo:up
2 • bun run --cwd packages/admin dev
3 • bun run demo:agent:register
```

Gate on :3000, portal on :3001. Register only bootstraps identity — the gate is about authorization.

DRIVE IT

With a real agent

```
curl localhost:3000/agent.md
...and follow it
```

Or the scripted CLI

```
demo:agent:get → 200
demo:agent:delegate → read-only token
demo:subagent:post → 403
```

SWIRLS_ Point OPENAPI_SPEC and UPSTREAM_URL at any spec — no code changes.